□□□□□□□□



Connect with trusted communities to share threat information

Defensomania

□□□□□□□□



Implement a central log management system

Defensomania

□□□□□□□□



Implement an event and alert management system for effective first triage

Defensomania

□□□□□□□□



Implement a case management system for effective incident handling

Defensomania

□□□□□□□□



Implement automation and orchestration to support analysts during first triage and investigations

Defensomania

□□□□□□□□



Implement detection use cases that cover the required scope

Defensomania

□□□□□□□□



Build know-how about new threats and train analysts

Defensomania

□□□□□□□□



Establish visibility into all critical assets and platforms

Defensomania

□□□□□□□□



Ensure central collection of relevant logs from systems in monitoring and incident response scope

Defensomania

□□□□□□□□



Deploy remote forensics software

Defensomania

□□□□□□□□



Deploy tools and capabilities for containment

Defensomania

□□□□□□□□



Prepare a decision tree and establish processes for GDPR readiness

Defensomania

□□□□□□□□



Attend or organize internal and external exercises

Defensomania

□□□□□□□□



Build a coordination and escalation team for major incidents

Defensomania

□□□□□□□□



Prepare and implement playbooks to assist analysts

Defensomania

□□□□□□□□



Prepare a list of critical assets for prioritisation

Defensomania

□□□□□□□□



Ensure the team knows all operating systems in use

Defensomania

□□□□□□□□



Establish different communication channels for various stakeholders

Defensomania

□□□□□□□□



Make a list of contact details for relevant peers

Defensomania

□□□□□□□□



Ensure collaboration between SOC and CSIRT and clarify responsibilities during an incident

Defensomania

□□□□□□□□



Build backup infrastructure for emergencies

Defensomania

□□□□□□□□



Perform regular threat hunting

Defensomania

□□□□□□□□



Implement detection for sensitive data indexed by public search engines

Defensomania

□□□□□□□□



Joker - invent a new preparation step

Defensomania

□□□□□□□□



Joker - invent a new preparation step

Defensomania

□□□□□□□□



Joker - invent a new preparation step

Defensomania

□□□□□□



Search for email attributes across all mailboxes

Defensomania

□□□□□□



Search for cron jobs on a Linux server

Defensomania

□□□□□□



Search for configuration settings on a remote system

Defensomania

□□□□□□



Search for malicious configuration changes on a remote system

Defensomania

□□□□□□



Search for processes on a remote host

Defensomania

□□□□□□



Search for files on a remote host

Defensomania

□□□□□□



Search for a file hash on a remote host

Defensomania

□□□□□□



Search for destination IPs in your network logs

Defensomania

□□□□□□



Search for source IPs in your network logs

Defensomania

□□□□□□



Search for domains in your network logs

Defensomania

□□□□□□



Search for referrers in your network logs

Defensomania

□□□□□□



Search for user agents in your network logs

Defensomania

□□□□□□



Search for URLs in your network logs

Defensomania

□□□□□□



Search for leaked data on public search engines and paste sites

Defensomania

□□□□□□



Detect credential abuse through login anomalies

Defensomania

□□□□□□



Detect credential leakage by monitoring external paste sites

Defensomania

□□□□□□



Detect leaked sensitive information in public source code repositories

Defensomania

□□□□□□



Detect lateral movement via named pipes

Defensomania

□□□□□□



Detect lateral movement via local admin accounts

Defensomania

□□□□□□



Detect lateral movement via credential abuse

Defensomania

□□□□□□



Detect malicious process injection

Defensomania

□□□□□□



Detect leaked information by actively monitoring cybercrime forums

Defensomania

□□□□□□



Detect unauthorized access on a remote system

Defensomania

□□□□□□



Detect unknown domain administrators in your user management

Defensomania

□□□□□□



Detect unknown local administrator accounts on a compromised system

Defensomania

□□□□□□



Detect in-memory malware on a remote host

Defensomania

□□□□□□



Check GDPR relevance

Defensomania

□□□□□□



Find the attacker through their real IP, leaked by bad OPSEC

Defensomania

□□□□□□



Correlate application grants, service principal activity and mailbox audit events to tell delegated access from normal sign-ins

Defensomania

□□□□□□



Joker - invent a new detection method

Defensomania

□□□□□□



Joker - invent a new detection method

Defensomania

□□□□□□



Joker - invent a new detection method

Defensomania

□□□□□□□□



Remove persistence mechanisms from the compromised system

Defensomania

□□□□□□□□



Remove malicious configuration settings from a compromised system

Defensomania

□□□□□□□□



Remove malware from a compromised system

Defensomania

□□□□□□□□



Stop a malicious process on a compromised system

Defensomania

□□□□□□□□



Stop data leakage from a compromised system

Defensomania

□□□□□□□□



Remove sensitive data from a publicly accessible website

Defensomania

□□□□□□□□



Start first response and gather volatile data

Defensomania

□□□□□□□□



Collect and analyse logs from a compromised system

Defensomania

□□□□□□□□



Collect evidence from a compromised system

Defensomania

□□□□□□□□



Collect files from a compromised system

Defensomania

□□□□□□□□



Collect the list of local accounts from a compromised system

Defensomania

□□□□□□□□



Create and collect a disk image of a compromised system

Defensomania

□□□□□□□□



Create a file system timeline from a disk image

Defensomania

□□□□□□□□



Extract C2 IPs from a malware sample

Defensomania

□□□□□□□



Search for activity related to the identified C2 servers

Defensomania

□□□□□□□□



Search for other affected systems after the initial compromise

Defensomania

□□□□□□□□



Block domain names

Defensomania

□□□□□□□□



Block IPs

Defensomania

□□□□□□□□



Block URLs

Defensomania

□□□□□□□□



Block access to an API

Defensomania

□□□□□□□□



Block an employee account

Defensomania

□□□□□□□□



Isolate a system

Defensomania

□□□□□□□□



Take a remote system offline

Defensomania

□□□□□□□□



Disable network connectivity on a remote system

Defensomania

□□□□□□□



Delete malicious emails from employee mailboxes

Defensomania

□□□□□□□□



Sinkhole a C2 server

Defensomania

□□□□□□□□



Capture traffic to a C2 server

Defensomania

□□□□□□□□



Force a password reset

Defensomania

□□□□□□□□



Add evidence to long-term storage

Defensomania

□□□□□□□□



Mitigate a DDoS attack

Defensomania

□□□□□□□□



Initiate hot patching or an immediate fix for the exploited vulnerability

Defensomania

□□□□□□□□



Create a GDPR notification

Defensomania

□□□□□□□□



Document indicators of attack and compromise centrally

Defensomania

□□□□□□□□



Share indicators of attack and compromise with the community

Defensomania

□□□□□□□



Revoke the malicious application's grant and sessions, record identifiers and audit evidence as urgency permits, and verify that access has stopped

Defensomania

□□□□□□□□



Joker - invent a new respond action

Defensomania

□□□□□□□□



Joker - invent a new respond action

Defensomania

□□□□□□□□



Joker - invent a new respond action

Defensomania

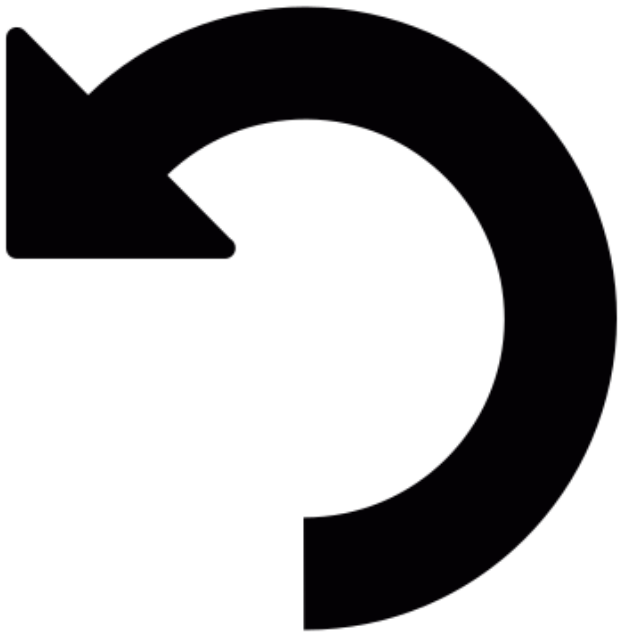
□□□□□□□□



Joker - invent a new respond action

Defensomania

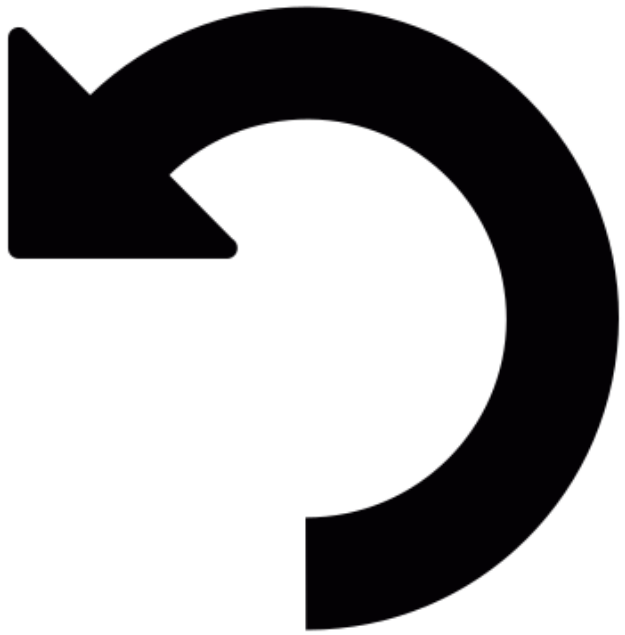
□□□□□□□□



Initiate a fresh installation of the compromised system from trusted install sources

Defensomania

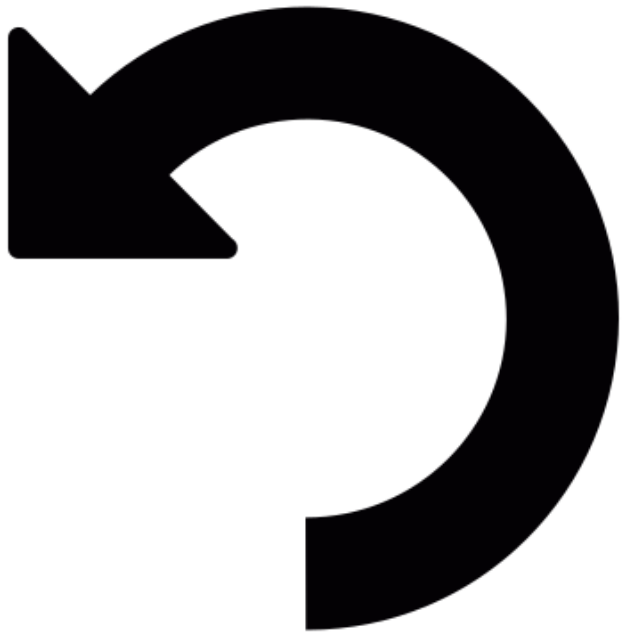
□□□□□□□□



Initiate patching of a critical vulnerability

Defensomania

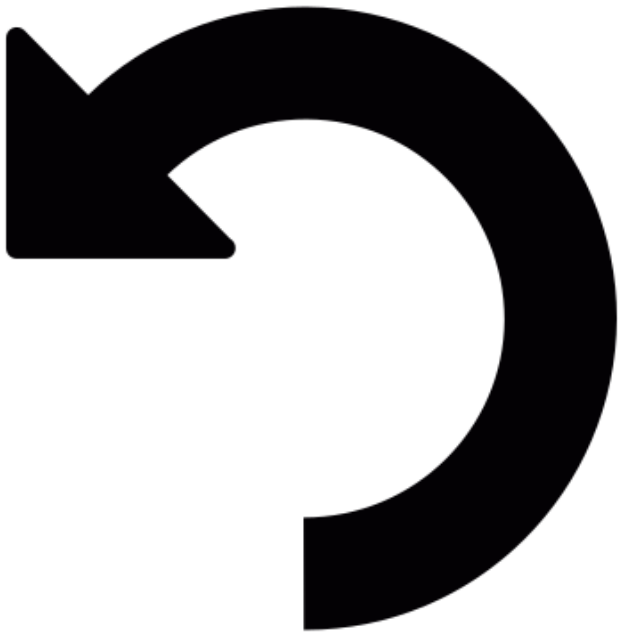
□□□□□□□□



Initiate an audit of a platform

Defensomania

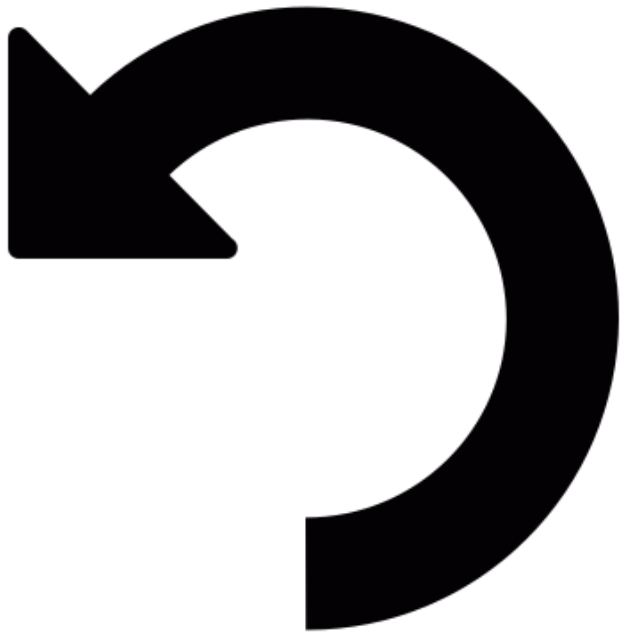
□□□□□□□□



Restore from backup

Defensomania

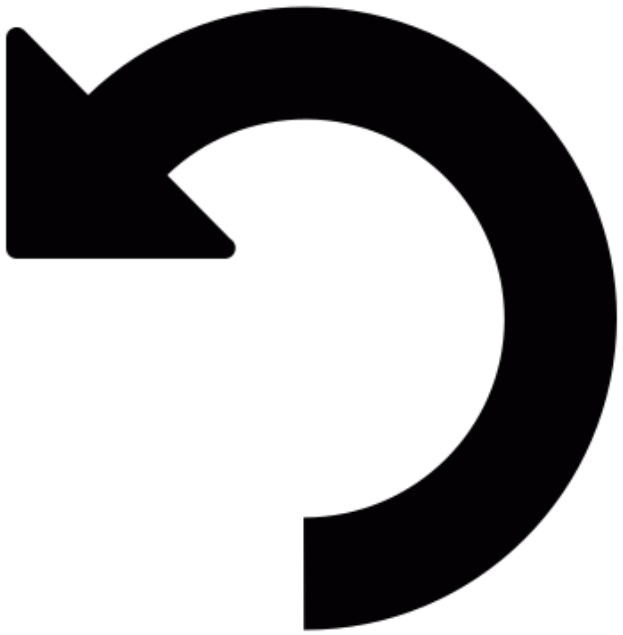
□□□□□□□□



Bring the service you took offline during the incident back online

Defensomania

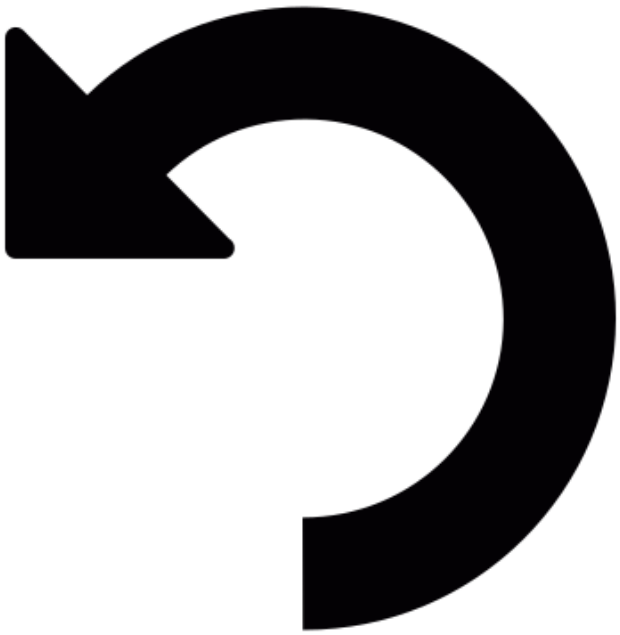
□□□□□□□□



Rotate API keys of a compromised account

Defensomania

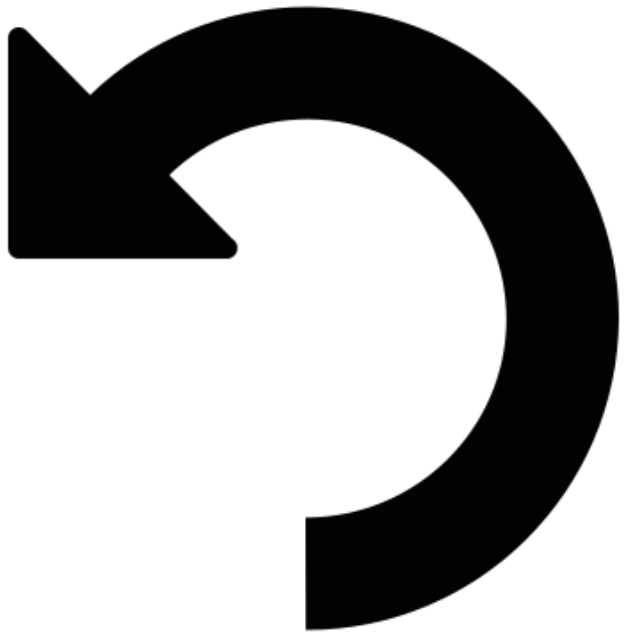
□□□□□□□□



Change credentials of a compromised service account that was disabled during the incident

Defensomania

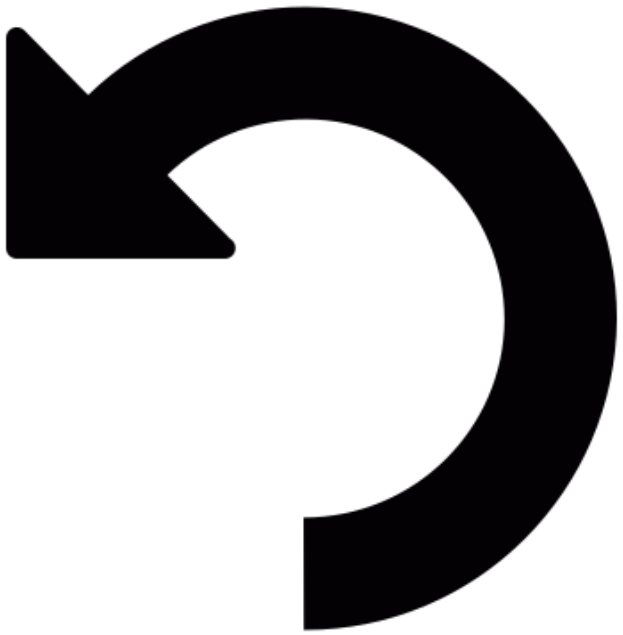
□□□□□□□□



Implement long-term monitoring through new detection use cases and incident response processes

Defensomania

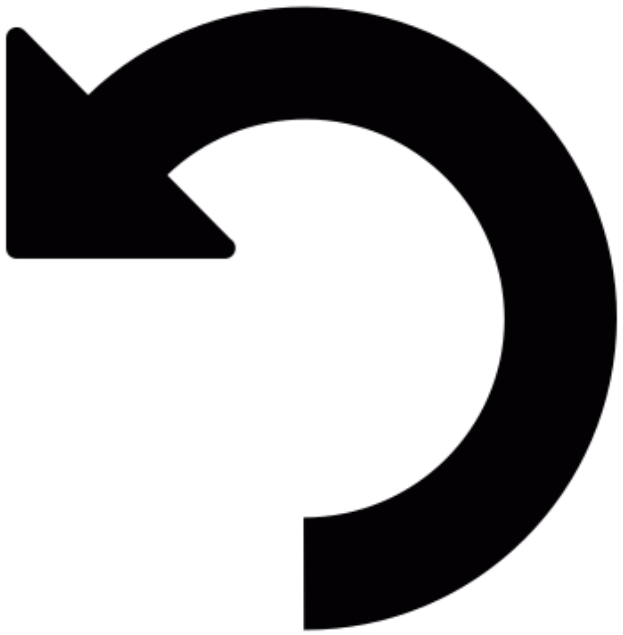
□□□□□□□□



Add an identified security gap to the policy framework

Defensomania

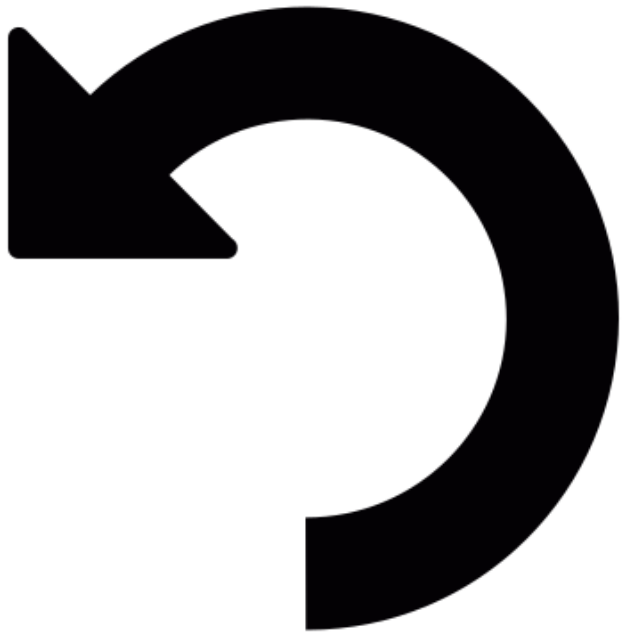
□□□□□□□□



Test the restoration in an isolated environment and validate monitoring before returning the service to its agreed scope

Defensomania

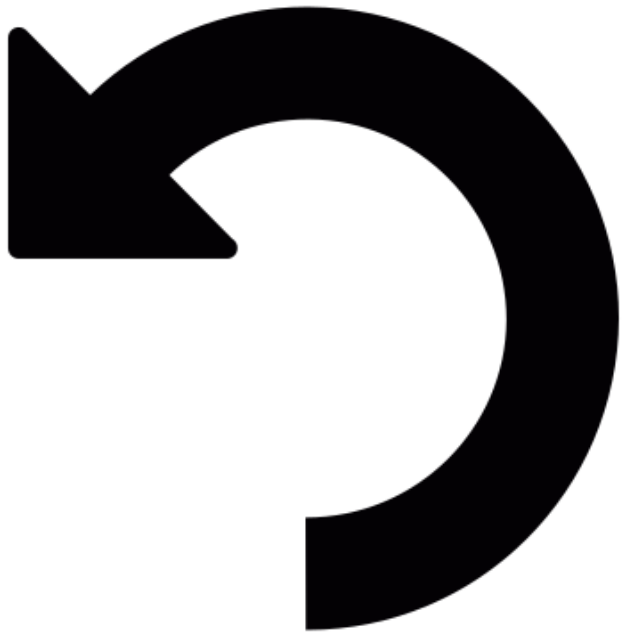
□□□□□□□□



Joker - invent a new recover action

Defensomania

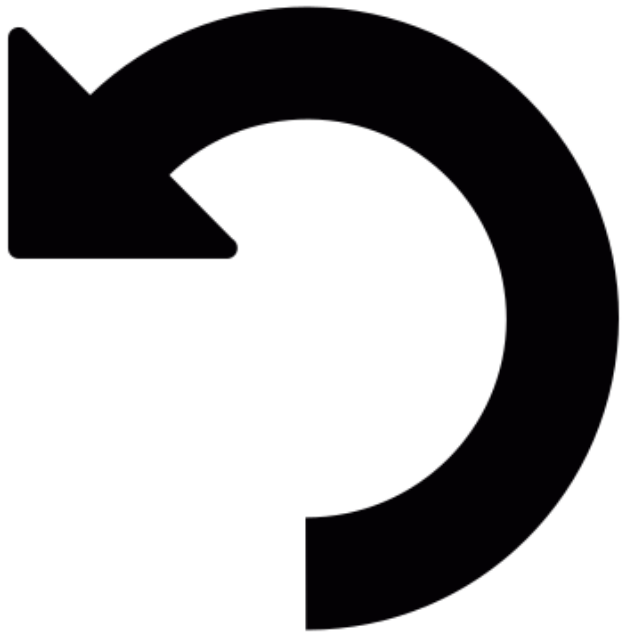
□□□□□□□□



Joker - invent a new recover action

Defensomania

□□□□□□□□



Joker - invent a new recover action

Defensomania

□□□□□□□□□□□□□□□□



Organize and run a lessons learned meeting

Defensomania

□□□□□□□□□□□□□□□□□



Define technical debt and report it accordingly

Defensomania

□□□□□□□□□□□□□□□□



Document results and new knowledge for the team and company

Defensomania

□□□□□□□□□□□□□□□□



Improve incident response processes

Defensomania

□□□□□□□□□□□□□□□□□



Improve incident detection capabilities

Defensomania

□□□□□□□□□□□□□□□□



Add new detection rules to internal and external repositories

Defensomania

□□□□□□□□□□□□□□□□



Record time boundaries, missing telemetry and uncertainty behind response metrics before comparing exercise results

Defensomania

□□□□□□□□□□□□□□□□



Joker - invent a new lessons learned step

Defensomania

□□□□□□□□□□□□□□□□



Joker - invent a new lessons learned step

Defensomania

□□□□□□□□□□□□□□□□



Joker - invent a new lessons learned step

Defensomania

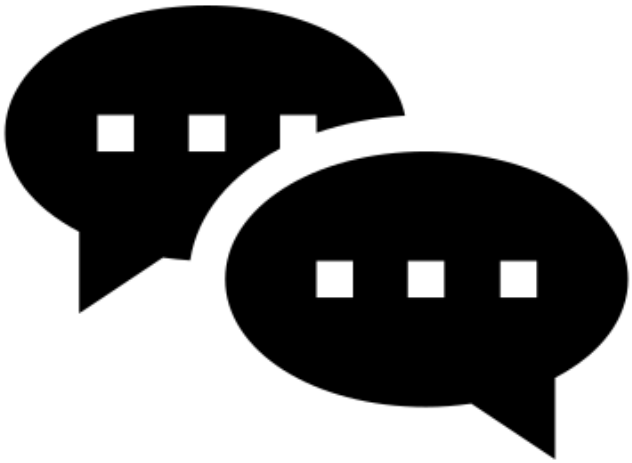
□□□□□□□□□□□□□□□□



Joker - invent a new lessons learned step

Defensomania

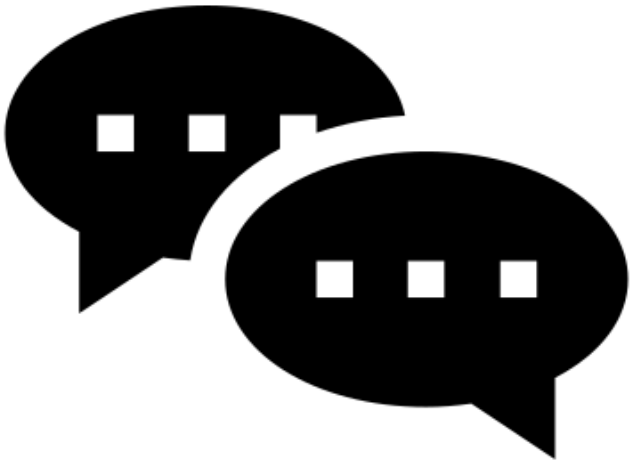
□□□□□□□□□□□□□□□



Publish an external news article

Defensomania

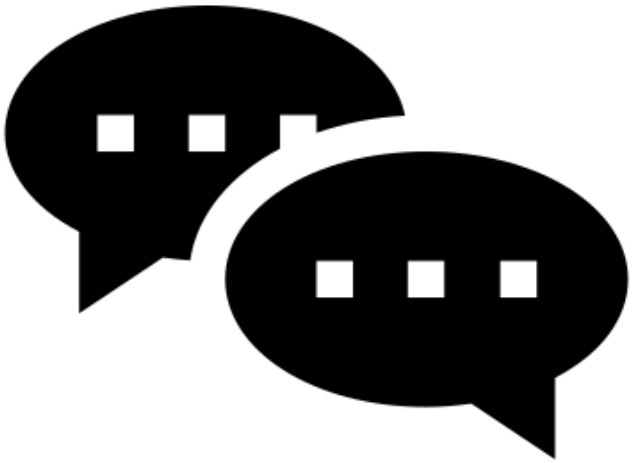
□□□□□□□□□□□□□□□



Inform the public relations department about possible questions from outside

Defensomania

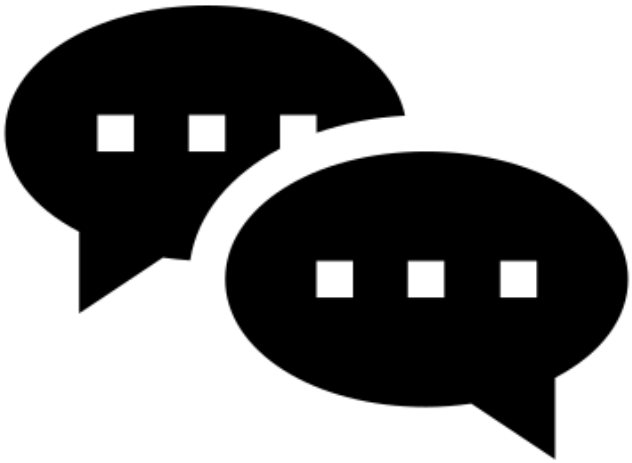
□□□□□□□□□□□□□□□



Communicate findings to management

Defensomania

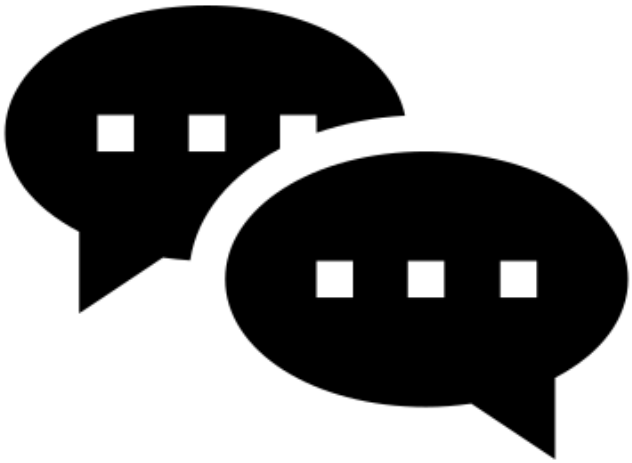
□□□□□□□□□□□□□□□



Create an incident report

Defensomania

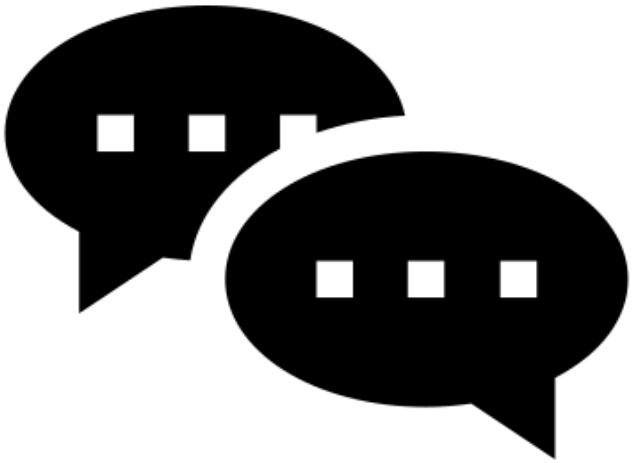
□□□□□□□□□□□□□□□



Write a reply to a request made on an external platform

Defensomania

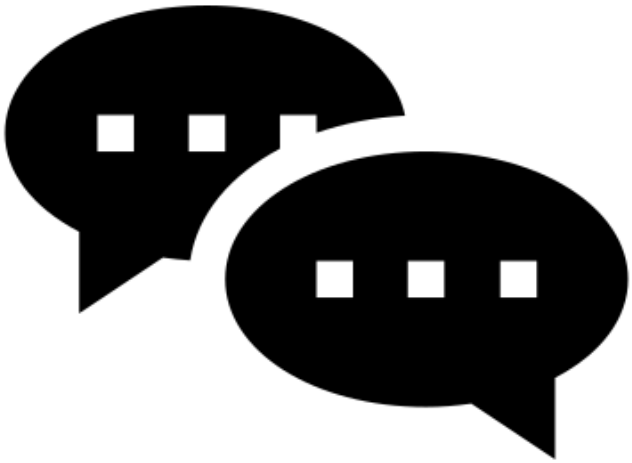
□□□□□□□□□□□□□□□



Joker - invent a new communication channel

Defensomania

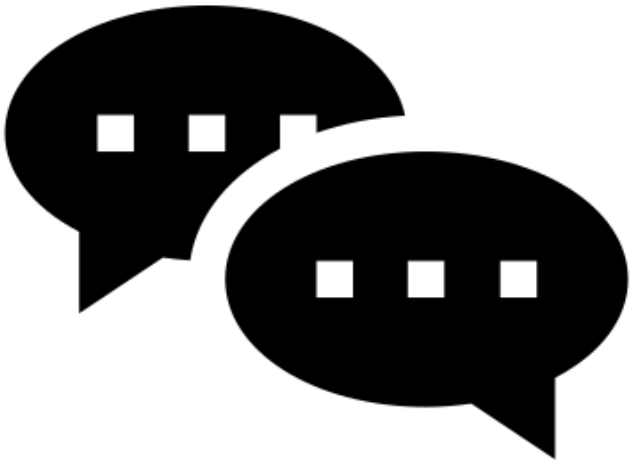
□□□□□□□□□□□□□□□



Joker - invent a new communication channel

Defensomania

□□□□□□□□□□□□□□□



Joker - invent a new communication channel

Defensomania

□□□□□□□□□



Your HRM software supplier was compromised and distributed a backdoored version. You may already have upgraded. Indicators of compromise are published.

Defensomania

□□□□□□□□□



Your national CERT has published indicators of compromise for your country and your industrial sector. Report back if you find any hits.

Defensomania

□□□□□□□□□



Several employee accounts were abused for further attacks against your customers. Initial analysis shows that all of them visited a typosquatted domain of your corporate portal.

Defensomania

□□□□□□□□□



An employee's workstation was infected with a banking Trojan that changed network settings and installed email monitoring software. It is linked to a recent malvertising campaign.

Defensomania

□□□□□□□□□



One of your ticketing systems is compromised and malware was placed on it. The malware connects to other systems reachable from that server.

Defensomania

□□□□□□□□□



Spear phishing attack against an employee, who reports logging into a look-alike company portal.

Defensomania

□□□□□□□□□



Spear phishing attack against an employee using a malicious document that executed code on the computer when opened.

Defensomania

□□□□□□□□□



An employee downloads malware disguised as a software package. It connects back to command and control servers using DNS.

Defensomania

□□□□□□□□□



A vulnerability on one of your servers was exploited and an attacker accessed the customer database. Increased bandwidth was registered on the network device.

Defensomania

□□□□□□□□□



A database with customer data was exposed to the Internet through a misconfigured firewall and someone on Twitter is leaking data from that database.

Defensomania

□□□□□□□□□



A public git repository leaked internal credentials and it's unclear whether they were already abused.

Defensomania

□□□□□□□□□



Servers of your main online service were targeted by a DDoS attack and are unavailable.

Defensomania

□□□□□□□□□



Malicious code was distributed to your endpoints during a routine update of a signed application.

Defensomania

□□□□□□□□□



A domain admin ran a malicious attachment after loudly proclaiming how dumb their users are for doing the same.

Defensomania

□□□□□□□□□



A security company has released an APT group PDF at BH USA. The list of IOCs includes a host in your ASN.

Defensomania

□□□□□□□□□



Every night, new corporate accounts are abused for sending spam.

Defensomania

□□□□□□□□□



Your email infrastructure was compromised. Attackers have full access to your mailboxes.

Defensomania

□□□□□□□□□



Attackers gained domain admin in your environment. Backdoor accounts were created and disk encryption software was activated.

Defensomania

□□□□□□□□□



An adversary has access to your Jenkins server.

Defensomania

□□□□□□□□□



An adversary has access to your vulnerable Jenkins server. Jenkins jobs with credentials are visible to everyone.

Defensomania

□□□□□□□□□



Someone is impersonating you to customer support at one of your service providers.

Defensomania

□□□□□□□□□



Your DNS was modified to respond with an attacker's DKIM key.

Defensomania

□□□□□□□□□



Due to a botched CI/CD script, the complete source code is exposed on production.

Defensomania

□□□□□□□□□



A bug in your web app allowed every record to be accessed via URL enumeration and IDOR.

Defensomania

□□□□□□□□□



Your subscription database was hacked. Thousands of new accounts were added and are hard to distinguish from existing ones.

Defensomania

□□□□□□□□□



A new paste on a public paste site contains password hashes and emails from your customer database from three years ago. More recent hashes are missing.

Defensomania

□□□□□□□□□



Your reception software leaked all of your visitor logs. They are available via torrent.

Defensomania

□□□□□□□□□



A script has been logging exported variables containing full user registration objects. The logs are full of plaintext passwords.

Defensomania

□□□□□□□□□



After a user's password reset, mailbox reads continue under an unfamiliar OAuth grant. A legitimate integration has the same scope. Business email must stay available.

Defensomania

□□□□□□□□□



A ransomware alert is followed by a gap in endpoint telemetry. The host appears online, backups have not yet been tested, and operations requests an immediate restart.

Defensomania

□□□□□□□□□



Joker - be evil and invent a new nightmare scenario that gets your team struggling. (If you want to go crazy, contribute your scary scenario for the sake of humanity.)

Defensomania

□□□□□□□□□



Joker - be evil and invent a new nightmare scenario that gets your team struggling. (If you want to go crazy, contribute your scary scenario for the sake of humanity.)

Defensomania

□□□□□□□□□



Joker - be evil and invent a new nightmare scenario that gets your team struggling. (If you want to go crazy, contribute your scary scenario for the sake of humanity.)

Defensomania

□□□□□□□□□



A developer just mistyped an upstream package name while installing it on their laptop. A malicious package was waiting for that typo and its post-install code is exfiltrating data.

Defensomania

□□□□□□□□□



An engineer mistyped a package name in a product repository. The package is malicious and exfiltrates CI/CD and production environment variables to a C&C server.

Defensomania

□□□□□□□□□



A malicious browser extension was installed on several corporate computers. It injects keyloggers into websites.

Defensomania

□□□□□□□□□



Your software build imports an employee's personal NPM package. The employee quits and vandalizes the package, causing a public incident.

Defensomania



An adversary takes control of your MDM service account. Your MDM support team cannot be reached for account recovery.

□□□□□□□□□



Your DNS was modified to respond with an attacker's DKIM key. Spear phishing emails will be signed by your domain in 30 minutes.

Defensomania

□□□□□□□□□



The certificates of your primary code signing process were compromised and used to sign malicious apps.

Defensomania

□□□□□□□□□



An employee left a firewall rule wide open after several hours of troubleshooting a network issue.

Defensomania

□□□□□□□□□



An employee left a firewall rule wide open after a faulty change request was implemented. Brute-force attempts were registered on previously protected servers.

Defensomania

□□□□□□□□□



You allow customers to upload sensitive information to your platform to share with others. However, the data was left unprotected and anyone could access and download it.

Defensomania

□□□□□□□□□



You were informed that one of your website directories used to share files with external parties was accessible and writable by any anonymous user. Suspicious files were found.

Defensomania

□□□□□□□□□



You were informed that your MDM solution was compromised and over 75% of your employees' mobile devices are infected with malware.

Defensomania

□□□□□□□□□



You were informed that your firewalls were compromised and malware was executed on these devices to steal information.

Defensomania